

Avance semanal

Divier Jácamo Álvarez

Cetav

Rol: Analista SOC L1

Métodos de clasificación de alarmas utilizados en los Centros de Operaciones de Seguridad SOC

Introducción

El aumento de la sofisticación de las ciberamenazas y la proliferación de herramientas de monitoreo ha resultado en una sobrecarga de alertas para los SOC; diversos estudios muestran que una gran proporción de estas alertas corresponden a falsos positivos o lo que aumentaría mucho al cansancio del analista y aumenta el riesgo de pasar por alto situaciones críticos en este contexto, la clasificación de alarmas se consolida como una función esencial para garantizar una respuesta eficaz ante incidentes de seguridad.

2. Proceso de triajes y clasificaciones de alarmas

En los SOC la clasificación de las alarmas está integrada en el proceso de distribución de alarmas, que consiste en la evaluación, categorización y priorización sistemática de las alertas de seguridad este proceso suele implicar los siguientes pasos la validación inicial de recepción y aceptación de alertas de sistemas como SIEM, EDR o IDS, donde se decide si la alerta corresponde a un evento real o a un falso positivo clasificando la alerta como benigna, sospechosa o maliciosa Priorizando en el impacto, la criticidad de los activos y la probabilidad de usos el escalar si se requiere un análisis más

profundo o una respuesta especializada este enfoque es consistente con las recomendaciones del NIST para manejar incidentes de seguridad.

3. Técnicas basadas en reglas y contexto

Los SOC tradicionales utilizan sistemas SIEM para clasificar alertas mediante reglas de correlación predefinidas estas reglas combinan eventos de diferentes fuentes y generan alertas cuando se cumplen ciertas condiciones, como el cumplimiento de indicadores conocidos de compromiso aunque este enfoque ofrece trazabilidad y control, tiene limitaciones frente a nuevas amenazas o técnicas de evasión porque depende en gran medida del conocimiento previo y el mantenimiento constante de reglas.

4. Automatización mediante SOAR

Las plataformas SOAR complementan SIEM al automatizar tareas repetitivas en el proceso de clasificación las guías real SOC SOAR le permitirían que enriquezca las alertas con inteligencia sobre amenazas al tomar decisiones de clasificación automatizadas para casos de baja complejidad y reducir el tiempo medio de análisis según gartner, el uso de SOAR ha reducido significativamente la carga operativa de los analistas de nivel 1.

5. Clasificación basada en aprendizaje automático

Los SOC avanzados incorporan técnicas de aprendizaje automático para mejorar la clasificación y priorización de alarmas los enfoques más comunes incluyen Aprendizaje supervisado entrenado sobre alertas previamente etiquetadas como verdaderas o falsas, aprendizaje no supervisado utilizado para detectar anomalías y agrupar alertas similares sistemas adaptativos que incorporan feedback de analistas para mejorar continuamente el modelo estas técnicas nos permiten reducir el ruido y descubrir patrones complejos que no pueden identificarse únicamente mediante reglas estáticas.

6. Contextualización mejorada y modelos híbridos.

Las técnicas de última generación utilizan modelos basados en gráficos para vincular alertas, eventos y activos, lo que permite la visualización de cadenas de ataques completas asimismo, alinear las alertas con marcos en tácticas y técnicas del adversario, mejorando la comprensión del contexto del incidente en la práctica, la mayoría de los SOC utilizan modelos híbridos en los que la automatización maneja alertas de bajo riesgo mientras los analistas humanos toman decisiones en casos inciertos o críticos.

Conclusiones

Los métodos de clasificación de alarmas en SOC reales han evolucionado desde enfoques manuales y basados en reglas hasta modelos híbridos que integran automatización, aprendizaje automático y análisis humano; no existe una metodología universal; en cambio,

Avance Semana 4

los SOC exitosos adaptan los procesos a nivel de madurez y perfil de riesgo clasificar correctamente las alertas no solo mejora la eficacia del SOC, sino que también aumenta la capacidad de detectar y responder a amenazas avanzadas.

Matriz de clasificación de alarmas basada en la gravedad del SOC

.Propósito de la matriz

La matriz de clasificación de alertas tiene como objetivo estandarizar la evaluación, priorización y respuesta a eventos de seguridad detectados por las herramientas SOC. El objetivo de criterios claros y repetibles es reducir la ambigüedad en la toma de decisiones, minimizar los falsos positivos y garantizar una asignación eficaz de los recursos del SOC

basada en el riesgo

Nivel de severidad	Descripción	Criterios Técnicos	Ejemplos de alertas	Acción Requerida	Responsable
Critica	Incidente confirmado	Evidencia clara	Ransomware activo	Contención inmediata	SOC L2
Alta	Actividad maliciosa	Indicadores confiables	Movimiento lateral	Investigación profunda	SOC L1 Y L2
Media	Actividad sospechosa	Anomalías de comportamiento	Escaneo interno	Monitoreo y análisis contextual	SOC L1
Baja	Evento anómalo	Desviación leve de comportamiento normal	Login fallido	Registro y seguimiento	SOC L1
Informática	Evento benigno	Eventos conocidos y controlados	Actualizaciones del sistema	Solo registro	Automatizado

Matriz de clasificacion de alertas basada en severidades

Severidad	Prioridad por defecto	Tiempo de Respuesta
Critica	Maxima	24 horas
Alta	Alta	4 horas
Media	Media	1 hora
Baja	Baja	15 minutos
Informativa	Muy baja	N/A

Criterios Tecnicos de clasificacion de Alertas criticas medias y bajas

Introducción

El creciente número de alertas generadas por las herramientas de seguridad modernas ha hecho que la clasificación de la gravedad sea un elemento crítico de las operaciones SOC sin criterios técnicos claramente definidos, los analistas enfrentarán decisiones inconsistentes, más falsos positivos y un uso ineficiente de los recursos en este contexto, es necesario establecer criterios formales para diferenciar objetivamente las alertas críticas, medias y bajas, teniendo en cuenta tanto los factores técnicos como el impacto potencial en la organización.

Método de diseño de criterios.

Avance Semana 4

La diferenciación de gravedad propuesta se basa en un enfoque de criterios múltiples, donde la gravedad de la advertencia se determina basándose en una combinación de varias especificaciones este enfoque sigue las mejores prácticas recomendadas por plataformas y permite procesos tanto manuales como automatizados.

Parámetros considerados: evidencia de actividad maliciosa, impacto en los recursos, criticidad de los recursos, probabilidad de explotación y escala del evento.

Este parámetro evalúa el grado de certeza técnica de que este evento corresponde a una actividad maliciosa real se tienen en cuenta los índices de compromiso las coincidencias con firmas conocidas y las correlaciones entre eventos.

Evidencia alta: uso confirmado, que involucra infraestructura maliciosa conocida.

Nivel de evidencia moderado: conducta aberrante persistente o empíricamente corregida bajo nivel de evidencia son eventos aislados sin correlación ni indicación confiable

Impacto en los activos se refiere al impacto real o potencial de un evento en la seguridad, integridad y disponibilidad de un sistema es el alto Impacto que es una violación directa de información confidencial o interrupción del servicio la de

Impacto medio es la interferencia limitada o atenuación parcial y el Impacto bajo es que no se detectaron consecuencias operativas.

Criticidad de los recursos afectados

La clasificación de activos se basa en el inventario de activos del SOC y su importancia para el negocio. Activos Críticos son sistemas que son necesarios para operar o contienen información sensible una ventaja importante es el soporte para servidores y aplicaciones internos. Recursos no críticos son la estación de trabajo del usuario o entorno de prueba.

Posibilidad de explotación

Esta medida evalúa la probabilidad de que una amenaza detectada sea explotada con éxito alta probabilidad las vulnerabilidades se están explotando activamente o se están utilizando exploits públicos que son la probabilidad media son vulnerabilidades conocidas pero sin signos de explotación activa las de probabilidad baja que son las condiciones operativas no se pueden lograr o no se pueden mitigar evaluar la escala espacial y temporal de un evento en un ambiente controlado y las de alcance alto Son las que se ven afectados múltiples recursos o hay movimiento lateral

Escala media es la repetición de un evento en el mismo tema. Baja escala son los eventos específicos y aislados clasificar las advertencias por nivel de gravedad y las advertencias importantes

Avance Semana 4

Las alertas críticas corresponden a incidentes confirmados o altamente probables, que afectan a activos críticos y tienen un impacto significativo. a menudo incorporan un alto nivel de pruebas técnicas, un impacto directo sobre la confidencialidad, la integridad o la disponibilidad y una amplia gama de aplicaciones ejemplos de este nivel incluyen ejecutar ransomware, robar datos o comunicarse activamente con servidores de comando y control.

Advertencias medias

Las alertas de gravedad media reflejan actividad sospechosa en curso que podría provocar incidentes con consecuencias más graves si no se investigan rápidamente. Aunque no existe una confirmación completa del cumplimiento, aún se puede observar una correlación entre eventos o anomalías persistentes.

Los ejemplos comunes incluyen el uso inusual de herramientas administrativas, análisis internos repetidos o intentos de autenticación correlacionados advertencia de nivel bajo las alertas de gravedad baja corresponden a eventos noticiosos o anomalías leves sin signos evidentes de actividad maliciosa tienen un impacto mínimo o nulo y, a menudo, afectan a recursos no críticos los ejemplos incluyen intentos fallidos de inicio de sesión o eventos programados fuera del horario comercial normal.

Modelos de decisión y umbrales de materialidad

Avance Semana 4

Para facilitar la automatización, cada parámetro se puede evaluar numéricamente en una escala del uno al tres, donde un parámetro es bajo y tres es alto la puntuación total le permite asignar niveles de gravedad según umbrales predefinidos este modelo promueve la reproducibilidad de la clasificación y reduce la dependencia del juicio personal del analista.

Conclusión

Establecer criterios técnicos formales para distinguir entre alertas críticas, moderadas y bajas mejorará la coherencia y eficiencia del proceso de clasificación SOC el modelo propuesto proporciona una base sólida tanto para la implementación operativa como para la justificación académica al integrar aspectos técnicos objetivos de acuerdo con estándares reconocidos su uso contribuye a una mejor priorización de los incidentes y una respuesta más eficaz a las amenazas a la seguridad

Análisis de tratamiento de alertas dentro del flujo operativo

Introducción

Una vez que las alertas de seguridad se clasifican por gravedad, el SOC debe integrarlas en un flujo de trabajo estructurado para garantizar una respuesta eficaz y coherente. La importancia actúa como un mecanismo de control que gobierna la asignación de recursos, el tiempo de respuesta y la profundidad del análisis. En este sentido, el tratamiento diferencial

de los niveles de alerta críticos, medios y bajos es fundamental para evitar la sobresaturación de los analistas y asegurar una atención priorizada a los incidentes de mayor impacto.

Flujo general de gestión de alarmas dentro del SOC

Un flujo de trabajo SOC típico incluye los siguientes pasos

Generar alertas utilizando herramientas de detección.

Enriquecimiento automatizado utilizando inteligencia sobre amenazas y contexto de activos.

Categorizar y priorizar según criterios importantes identificados.

Analizar personas por nivel de gravedad respuesta y protección, en su caso

Cierre y retroalimentación, incluidas las lecciones aprendidas el nivel de gravedad determina cómo se realiza cada uno de estos pasos.

3. Manejar alertas críticas

Las alertas críticas se envían al flujo SOC con la máxima prioridad, lo que activa inmediatamente los mecanismos de notificación y presentación de informes. Estas alertas a menudo se generan en base a correlaciones complejas o hallazgos de alta confianza, como indicadores verificados de violaciones de seguridad.

Avance Semana 4

Análisis e informes

El análisis preliminar se puede realizar automáticamente, pero se pasa rápidamente a analistas de nivel 2 o 3. El objetivo de esta fase es confirmar el alcance de la infracción, identificar técnicas de ataque y evaluar el verdadero impacto en los recursos críticos.

Respuesta y prevenciones

Las advertencias críticas desaparecieron de las acciones de soporte inmediato, las historias del sistema operativo, la revocación de credenciales o el bloqueo de mensajes maliciosos. Estas actividades se pueden automatizar utilizando SOAR, pero se requiere el juicio humano para lograr altos niveles de impacto operativo

Cierre y retroalimentación

Cerrar las alertas críticas requiere documentación detallada del incidente, análisis de la causa raíz y ajuste de las reglas, scripts o modelos de detección. Esta retroalimentación es importante para mejorar las capacidades SOC futuras. 4. Admite advertencia media

Análisis de contexto

Las alertas de nivel medio generalmente se asignan a analistas de Nivel 1 o Nivel 2, quienes realizan un análisis contextual más profundo para determinar si una actividad sospechosa tiene el potencial de convertirse en un incidente grave. En esta etapa, se analizarán patrones

Avance Semana 4

históricos, comportamiento de los usuarios y correlaciones adicionales.

Decisión de actualizar

El manejo de estas advertencias se caracteriza por una toma de decisiones condicional. Si se identifican nuevos signos de infracción o expansión, la alerta puede reclasificarse como crítica y tomarse las medidas adecuadas.

Retroalimentación controlada

Las acciones para responder a alertas de nivel medio suelen ser limitadas y reversibles, e incluyen aumentar el monitoreo, realizar análisis adicionales o requerir revisión de otras áreas técnicas.

Cierre

Si no se confirma la actividad maliciosa, la alerta se considerará un evento falso positivo o inofensivo y se registrará la información relacionada para mejorar la clasificación futura.

Manejo de alarma baja

Las alertas de baja gravedad se gestionan en su mayoría de forma automática. El SOC puede aplicar políticas automáticas de contención, agrupamiento o cierre si determina que el evento no representa un riesgo significativo.

Avance Semana 4

Análisis mínimo

En el caso de la verificación humana, el análisis es superficial y se limita a comprobar si el evento está asociado a alertas de mayor importancia. Estas alertas suelen ser gestionadas por analistas de nivel

Incluso cuando no hay respuesta, las alertas de bajo nivel se conservan para análisis estadístico y detección de tendencias, lo que le permite identificar patrones emergentes o cambios en el comportamiento normal

Conclusión

El análisis del manejo de alertas en el flujo SOC muestra que la validez es importante para la toma de decisiones operativas. Si bien las alertas críticas requieren atención inmediata y análisis dedicado, las alertas medias actúan como un mecanismo de detección temprana y las alertas bajas le permiten mantener la visibilidad sin estresar a su equipo un flujo SOC claramente definido, respaldado por criterios técnicos sólidos, mejorará significativamente la eficacia de la gestión de incidentes de seguridad.

Referencias

Jaquith, A. (2007). *Security metrics: Replacing fear, uncertainty, and doubt*. Addison-Wesley.

Perry, W., & Sundaramurthy, S. (2020). Measuring the effectiveness of SOC operations.

IEEE Security & Privacy, 18(3), 65–72.

<https://doi.org/10.1109/MSEC.2020.2983331>

MITRE. (2023). *MITRE ATT&CK®: A knowledge base of adversary tactics and techniques*.

<https://attack.mitre.org>

Strom, B. E., Applebaum, A., Miller, D. P., Nickels, K. C., Pennington, A. G., & Thomas, C. B. (2018). *MITRE ATT&CK: Design and philosophy*. MITRE Corporation.

Sarker, I. H. (2021). Machine learning: Algorithms, real-world applications and research directions. *SN Computer Science*, 2(3), 1–21.

<https://doi.org/10.1007/s42979-021-00592-x>

Sommer, R., & Paxson, V. (2010). Outside the closed world: On using machine learning for network intrusion detection. *IEEE Symposium on Security and Privacy*, 305–316.

<https://doi.org/10.1109/SP.2010.25>

Gartner. (2023). *Market guide for security orchestration, automation and response (SOAR)*. Gartner Research.

IBM Security. (2021). *SOAR playbooks and automation in incident response*. IBM Corporation.

Splunk Inc. (2022). *Security operations best practices*. Splunk Documentation.

Alberts, C., & Dorofee, A. (2002). *Managing information security risks: The OCTAVE approach*. Addison-Wesley.

ISO/IEC. (2018). *ISO/IEC 27005: Information security risk management*.
International Organization for Standardization.

Stoneburner, G., Goguen, A., & Feringa, A. (2002). *Risk management guide for information technology systems* (NIST SP 800-30). National Institute of Standards and Technology.

National Institute of Standards and Technology. (2012). *Computer security incident handling guide* (NIST SP 800-61 Rev. 2).
<https://doi.org/10.6028/NIST.SP.800-61r2>

ISO/IEC. (2016). *ISO/IEC 27035-1: Information security incident management — Principles of incident management*. International Organization for Standardization.

